

Cyber Risk Assessment – Findings Summary

Company Overview

Company: ITech Solutions
Industry: SaaS (CRM Software)
Employees: 300
Compliance Requirements: SOX, HIPAA, General Data Protection
Data Handled: PII, financial data, customer support tickets

1. Key Risks Identified

Risk ID	Description	Risk Rating	Business Impact Summary
R001	Unauthorized access to employee records	High	Potential HIPAA violation, \$100K fines, loss of trust
R002	Phishing attack targeting finance team	Critical	Risk of \$500K loss, inaccurate financial reporting
R003	Outdated software on customer-facing app	High	Customer data breach, reputational damage
R004	Missing audit logging for admin actions	Medium	Undetected insider threats, non-compliance with audits

2. Control Mapping (NIST 800-53)

Control ID	Description	Plain English Purpose	Risk(s) Mitigated	Status
------------	-------------	-----------------------	-------------------	--------

AC-2	Account Management	Review/remove inactive accounts	R001	In Progress
IA-2	Identification & Authentication	Enforce MFA for privileged users	R001, R002	Implemented
SI-2	Flaw Remediation	Patch vulnerable systems quickly	R003	Not Started
AU-2	Audit Events	Log and retain admin actions	R004	In Progress
AT-2	Security Awareness Training	Train staff to identify phishing attempts	R002	Implemented

3. Remediation Plan & Metrics

Risk ID	Severity	Controls	Owner	Timeline	KPI / Metric
R001	High	AC-2, IA-2	IT Security Lead	30 days	100% privileged accounts with MFA
R002	Critical	AT-2, IA-2	Training Manager	15 days	95% staff complete phishing training
R003	High	SI-2	DevOps Lead	60 days	90% patches applied within SLA
R004	Medium	AU-2	Security Analyst	45 days	Audit logs retained ≥ 12 months

✓ Summary of Findings

- **Critical Risk:** Phishing attacks (R002) require urgent attention due to potential financial and compliance exposure.
- **Progress:** Two major controls (IA-2, AT-2) are fully implemented, lowering organizational risk.
- **Gaps:** Patching processes (R003) and audit logs (R004) still pose threats.
- **Recommendation:** Prioritize patching policy (SI-2) and complete audit logging implementation (AU-2).